The Audit Room: Design and Operating Effectiveness Workbook

Pannon Office Services Ltd. | Review period: 1–31 October 2026 | Audit date: 9 November 2026

Team: _____ Team member / workstream: _____

Date: _____ Audit manager: _____

Purpose and scope

Use this workbook with HR-POL-01, IAM-POL-01, CHG-POL-01 and the Audit Evidence Workbook. It covers selected onboarding/offboarding, access-management and change-management processes. It is a limited classroom audit sample; do not make an organization-wide or certification conclusion.

How to work

- For Design, assess whether the policy sets a clear, suitable and testable expectation. Write the policy reference and explain your reasoning.
- For Operating Effectiveness, request and review appropriate operational evidence. The suggested document types are starting points only; choose and document your own sample and test procedure.
- Cite exact document IDs and record or row references. A policy describes expected practice; it does not by itself prove that the practice operated.
- Use one conclusion for Design and one for Operating Effectiveness: Supported; Gap identified; More evidence needed; or Not tested. Explain evidence limitations instead of assuming an unlisted record does not exist.
- The “What good looks like” note is a plain-language control explanation, not a verdict on the company’s evidence.

ISO/IEC 27001:2022 (including Amendment 1:2024) provides the audit framework. Annex A control selection depends on the organization’s risks, obligations and Statement of Applicability; it is not a universal checklist. The specific deadlines and approval rules in the policies are Pannon’s exercise requirements, not deadlines prescribed by ISO.

A. People, onboarding and offboarding

A1. Leaver access removal

QUESTION | Do HR-POL-01 and IAM-POL-01 establish a clear trigger, deadline, responsibility and scope for removing access when employment ends?

DESIGN — Is the control adequately designed?

Consider: Does the design address central sign-in, assigned applications, mailbox handover and the response to a missed deadline?

Policy / section reference	
Design assessment and reasoning	

Design conclusion: ☐ **Supported** ☐ **Gap identified** ☐ **More evidence needed** ☐ **Not tested**

OPERATING EFFECTIVENESS — Did the control operate in the sample?

Typical evidence sources: HR event list (EX-HR-01); access tickets (EX-IAM-01); account export (EX-IAM-02).

Sample / records selected	
Test procedure performed	
Evidence references and result / reasoning	
Limitation or focused follow-up request	

Operating-effectiveness conclusion: ☐ **Supported** ☐ **Gap identified** ☐ **More evidence needed** ☐ **Not tested**

CONTROL EXPLANATION | What good looks like

Good looks like a clear event and clock start, a measurable deadline, named HR and IT responsibilities, removal of central and assigned application access, time-stamped evidence, and a defined response when the deadline is missed.

A. People, onboarding and offboarding

A2. Joiner and mover access

QUESTION | Do HR-POL-01 and IAM-POL-01 establish suitable approval and access-change requirements for new starters and role changes?

DESIGN — Is the control adequately designed?

Consider: Consider approval authority, sensitive access, the timing of provisioning, and removal of access that is no longer needed.

Policy / section reference	
Design assessment and reasoning	

Design conclusion: ☐ **Supported** ☐ **Gap identified** ☐ **More evidence needed** ☐ **Not tested**

OPERATING EFFECTIVENESS — Did the control operate in the sample?

Typical evidence sources: HR event list (EX-HR-01); access tickets (EX-IAM-01); account export (EX-IAM-02).

Sample / records selected	
Test procedure performed	
Evidence references and result / reasoning	
Limitation or focused follow-up request	

Operating-effectiveness conclusion: ☐ **Supported** ☐ **Gap identified** ☐ **More evidence needed** ☐ **Not tested**

CONTROL EXPLANATION | What good looks like

Good looks like an authorized employment event, approval before access is granted or changed, access limited to the approved role, timely removal of obsolete access, and records attributable to the person and request.

A. People, onboarding and offboarding

A3. Security induction

QUESTION | Does HR-POL-01 define who must complete security induction, who is responsible, and when it must be completed?

DESIGN — Is the control adequately designed?

Consider: Consider whether the policy also defines the minimum content and what evidence demonstrates completion of that content.

Policy / section reference	
Design assessment and reasoning	

Design conclusion: ☐ **Supported** ☐ **Gap identified** ☐ **More evidence needed** ☐ **Not tested**

OPERATING EFFECTIVENESS — Did the control operate in the sample?

Typical evidence sources: HR event list (EX-HR-01); related onboarding or access records in EX-IAM-01.

Sample / records selected	
Test procedure performed	
Evidence references and result / reasoning	
Limitation or focused follow-up request	

Operating-effectiveness conclusion: ☐ **Supported** ☐ **Gap identified** ☐ **More evidence needed** ☐ **Not tested**

CONTROL EXPLANATION | What good looks like

Good looks like a defined audience, relevant minimum topics, a clear completion deadline, and evidence that the required induction was completed and can be checked against the employee and employment event.

B. Access management

B1. Human administrator accounts

QUESTION | Do IAM-POL-01 requirements provide suitable safeguards for human administrator accounts?

DESIGN — Is the control adequately designed?

Consider: Consider unique and separate accounts, approval before provisioning, authentication requirements, and recurring review.

Policy / section reference	
Design assessment and reasoning	

Design conclusion: ☐ **Supported** ☐ **Gap identified** ☐ **More evidence needed** ☐ **Not tested**

OPERATING EFFECTIVENESS — Did the control operate in the sample?

Typical evidence sources: access requests (EX-IAM-01); account and authentication export (EX-IAM-02); privileged-access review (EX-IAM-03).

Sample / records selected	
Test procedure performed	
Evidence references and result / reasoning	
Limitation or focused follow-up request	

Operating-effectiveness conclusion: ☐ **Supported** ☐ **Gap identified** ☐ **More evidence needed** ☐ **Not tested**

CONTROL EXPLANATION | What good looks like

Good looks like individual accountability, least privilege, a separate named administrator account, required approvals, effective MFA on human administrator accounts, and a traceable periodic review.

B. Access management

B2. Service identity safeguards

QUESTION | Does IAM-POL-01 define when a service identity may use authentication arrangements different from human accounts?

DESIGN — Is the control adequately designed?

Consider: Consider whether the exception conditions are specific, approved and subject to ownership and review.

Policy / section reference	
Design assessment and reasoning	

Design conclusion: ☐ **Supported** ☐ **Gap identified** ☐ **More evidence needed** ☐ **Not tested**

OPERATING EFFECTIVENESS — Did the control operate in the sample?

Typical evidence sources: service-identity request (EX-IAM-01); account export (EX-IAM-02); privileged-access review (EX-IAM-03).

Sample / records selected	
Test procedure performed	
Evidence references and result / reasoning	
Limitation or focused follow-up request	

Operating-effectiveness conclusion: ☐ **Supported** ☐ **Gap identified** ☐ **More evidence needed** ☐ **Not tested**

CONTROL EXPLANATION | What good looks like

Good looks like a narrowly scoped identity with a named accountable owner, interactive sign-in disabled, a protected secret, documented job purpose, and periodic review. Any exception is valid only when its stated conditions are met.

B. Access management

B3. Privileged-access review

QUESTION | Does IAM-POL-01 define a complete and repeatable review of privileged access?

DESIGN — Is the control adequately designed?

Consider: Consider review frequency, reviewer independence, required records, and the timeframe for acting on access no longer needed.

Policy / section reference	
Design assessment and reasoning	

Design conclusion: ☐ **Supported** ☐ **Gap identified** ☐ **More evidence needed** ☐ **Not tested**

OPERATING EFFECTIVENESS — Did the control operate in the sample?

Typical evidence sources: account export (EX-IAM-02); privileged-access review extract (EX-IAM-03); linked access tickets in EX-IAM-01.

Sample / records selected	
Test procedure performed	
Evidence references and result / reasoning	
Limitation or focused follow-up request	

Operating-effectiveness conclusion: ☐ **Supported** ☐ **Gap identified** ☐ **More evidence needed** ☐ **Not tested**

CONTROL EXPLANATION | What good looks like

Good looks like a complete account-level review by an appropriate reviewer, recorded retain/remove decisions and references, and completed follow-up within the stated timeframe.

C. Change management

C1. Risk-rating design

QUESTION | Does CHG-POL-01 provide a sufficiently clear basis for rating production changes and routing them for approval?

DESIGN — Is the control adequately designed?

Consider: Consider whether risk levels have usable criteria, whether a rationale is recorded, and whether approval requirements follow from the rating.

Policy / section reference	
Design assessment and reasoning	

Design conclusion: ☐ **Supported** ☐ **Gap identified** ☐ **More evidence needed** ☐ **Not tested**

OPERATING EFFECTIVENESS — Did the control operate in the sample?

Typical evidence sources: change register (EX-CHG-01); change tickets and deployment records (EX-CHG-02); approved standard models (EX-CHG-03).

Sample / records selected	
Test procedure performed	
Evidence references and result / reasoning	
Limitation or focused follow-up request	

Operating-effectiveness conclusion: ☐ **Supported** ☐ **Gap identified** ☐ **More evidence needed** ☐ **Not tested**

CONTROL EXPLANATION | What good looks like

Good looks like repeatable criteria connecting change impact to a risk level and approval route, with a rationale that allows a reviewer to understand the classification.

C. Change management

C2. Planned and standard change execution

QUESTION | Do CHG-POL-01 requirements establish a suitable process for planned and standard production changes?

DESIGN — Is the control adequately designed?

Consider: Consider when records, approvals, tests, rollback steps and Change Advisory Board decisions are required.

Policy / section reference	
Design assessment and reasoning	

Design conclusion: ☐ **Supported** ☐ **Gap identified** ☐ **More evidence needed** ☐ **Not tested**

OPERATING EFFECTIVENESS — Did the control operate in the sample?

Typical evidence sources: change register (EX-CHG-01); change tickets and deployment records (EX-CHG-02); standard model catalogue (EX-CHG-03); board minutes (EX-CHG-02).

Sample / records selected	
Test procedure performed	
Evidence references and result / reasoning	
Limitation or focused follow-up request	

Operating-effectiveness conclusion: ☐ **Supported** ☐ **Gap identified** ☐ **More evidence needed** ☐ **Not tested**

CONTROL EXPLANATION | What good looks like

Good looks like a documented change before work begins, appropriate approval and successful testing before deployment, usable rollback steps, required board decisions, and a recorded implementation result.

C. Change management

C3. Standard-change models

QUESTION | Does CHG-POL-01 define how standard-change models are approved, bounded, tested and periodically reviewed?

DESIGN — Is the control adequately designed?

Consider: Consider the control over first use, permitted scope, test conditions, model ownership and review frequency.

Policy / section reference	
Design assessment and reasoning	

Design conclusion: ☐ **Supported** ☐ **Gap identified** ☐ **More evidence needed** ☐ **Not tested**

OPERATING EFFECTIVENESS — Did the control operate in the sample?

Typical evidence sources: change register (EX-CHG-01); approved standard models (EX-CHG-03); board minutes (EX-CHG-02).

Sample / records selected	
Test procedure performed	
Evidence references and result / reasoning	
Limitation or focused follow-up request	

Operating-effectiveness conclusion: ☐ **Supported** ☐ **Gap identified** ☐ **More evidence needed** ☐ **Not tested**

CONTROL EXPLANATION | What good looks like

Good looks like a repeatable and bounded activity approved before use, with clear test and rollback conditions, an accountable owner, and periodic review.

C. Change management

C4. Emergency changes

QUESTION | Does CHG-POL-01 define when the emergency route is allowed and what authorization, recordkeeping and retrospective review it requires?

DESIGN — Is the control adequately designed?

Consider: The urgency threshold, pre-implementation authority, documentation, retrospective approval and follow-up deadlines.

Policy / section reference	
Design assessment and reasoning	

Design conclusion: ☐ **Supported** ☐ **Gap identified** ☐ **More evidence needed** ☐ **Not tested**

OPERATING EFFECTIVENESS — Did the control operate in the sample?

Typical evidence sources: change register (EX-CHG-01); change tickets and deployment records (EX-CHG-02); board minutes (EX-CHG-02).

Sample / records selected	
Test procedure performed	
Evidence references and result / reasoning	
Limitation or focused follow-up request	

Operating-effectiveness conclusion: ☐ **Supported** ☐ **Gap identified** ☐ **More evidence needed** ☐ **Not tested**

CONTROL EXPLANATION | What good looks like

Good looks like an appropriately urgent condition, authorized route before implementation, documented reason and safeguards, timely retrospective review by required roles, and recorded result and follow-up.